实验 4　SSL 抓包实验

提交日期：截至 2024 年 12 月 14 日 24 点
提交方式：将实验报告上传至课程网站 sep.ucas.ac.cn

一、实验目的

1. 了解 TLS/SSL 协议过程
2. 通过抓包验证 TLS/SSL 协议的实现

二、实验环境

Wireshark

三、实验内容

SSL(Socket Secure Layer)是 TLS(Transport Layer Security)的前身，TLS 1.0 在 SSL 3.0 的基础上提出，即 TLS 是 SSL 的后续版本。TLS 和 SSL 的原理相同，但加密方法有所不同，目前常用的是 TLS1.2。SSL/TLS 协议是使用最广泛的密码通信方法，它应用了密码学中的对称密码，消息认证码，公钥密码，数字签名，伪随机数生成器等机制，属于传输层安全协议。基于 SSL/TLS 的 HTTP，就叫 HTTP over SSL 或 HTTP over TLS，也就是常说的 HTTPS（HTTP Secure）。通过 wireshark 抓取 HTTPS 包，标明 TLS 握手过程（以 TLS1.2 为例），如图 1。

192.168.134.125	119.3.32.96	TLSv1.2	571	Client Hello (SNI=api.vc.bilibili.com)
119.3.32.96	192.168.134.125	TLSv1.2	1514	Server Hello
119.3.32.96	192.168.134.125	TLSv1.2	1510	Certificate, Server Key Exchange, Server Hello Done
192.168.134.125	119.3.32.96	TLSv1.2	180	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
192.168.134.125	119.3.32.96	TLSv1.2	159	Application Data
192.168.134.125	119.3.32.96	TLSv1.2	1318	Application Data
119.3.32.96	192.168.134.125	TLSv1.2	312	New Session Ticket, Change Cipher Spec, Encrypted Handshake Message
119.3.32.96	192.168.134.125	TLSv1.2	1082	Application Data, Application Data, Application Data, Application Data
192.168.134.125	119.3.32.96	TLSv1.2	92	Application Data
192.168.134.125	119.3.32.96	TLSv1.2	170	Application Data
119.3.32.96	192.168.134.125	TLSv1.2	866	Application Data
119.3.32.96	192.168.134.125	TLSv1.2	93	Application Data

图 1

在报告中需要体现：
1. 使用 Wireshark 抓到的 TLS 握手过程（如图 1）
2. 找到服务端选择的加密套件（cipher suite）并在报告中标明，如图 2

```
Transport Layer Security
  TLSv1.2 Record Layer: Handshake Protocol: Server Hello
    Content Type: Handshake (22)
    Version: TLS 1.2 (0x0303)
    Length: 74
    Handshake Protocol: Server Hello
      Handshake Type: Server Hello (2)
      Length: 70
      Version: TLS 1.2 (0x0303)
      Random: 8b8d61d427299b3a6643075565857d7d24e92f4a17f7f3ebc991ce09f1cf3822
      Session ID Length: 0
      Cipher Suite: TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)
      Compression Method: null (0)
      Extensions Length: 30
      Extension: server_name (len=0)
      Extension: renegotiation_info (len=1)
```

图 2

3. 同样的，找到图 3 中的服务端公钥 A，客户端随机数，服务端随机数，预主秘钥（premaster key）并在报告中标明

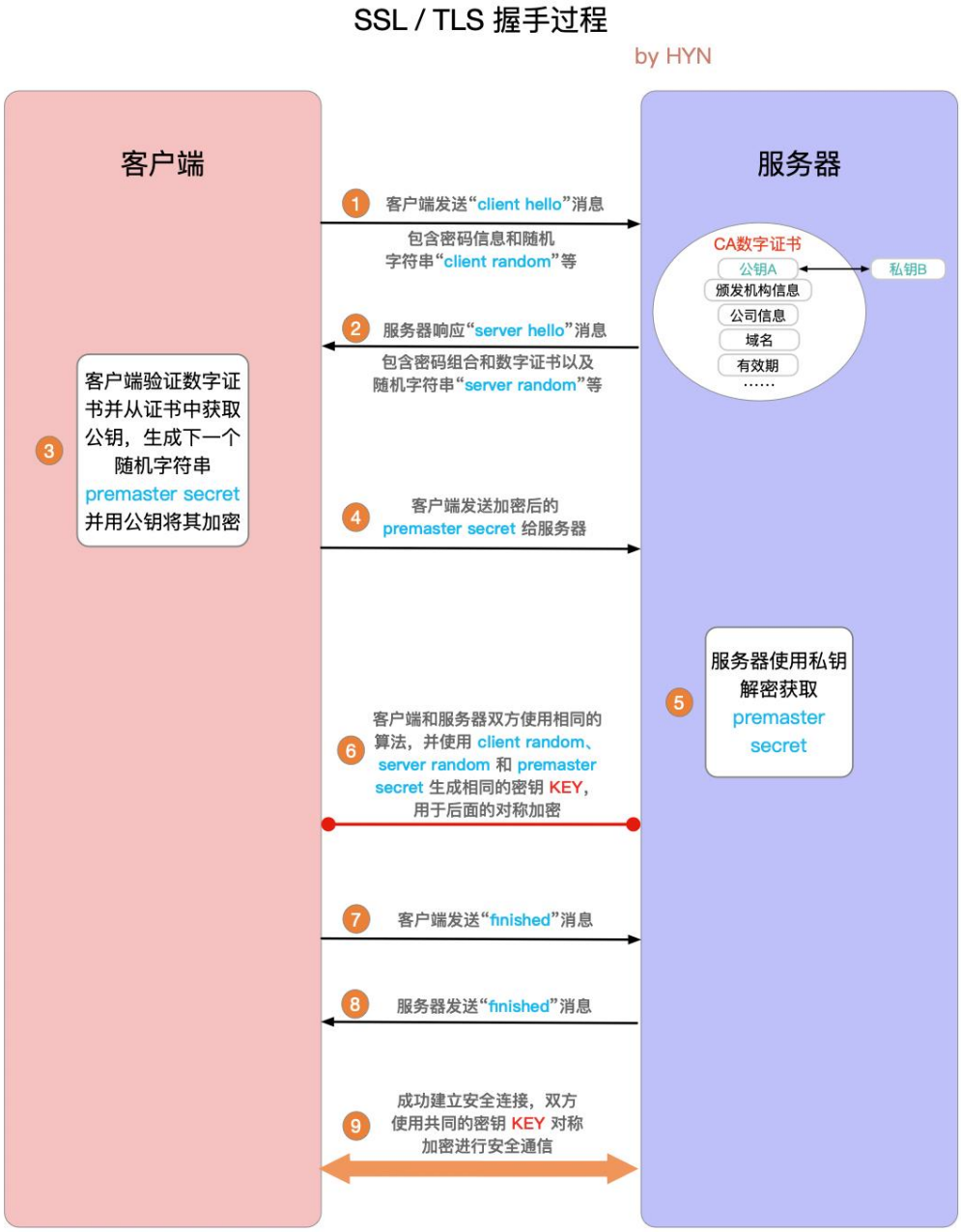


图 3

4. 将图 3 中的步骤号（1-9）在握手流程截图的对应位置标出，以步骤 1,2,9 为例，如下图：

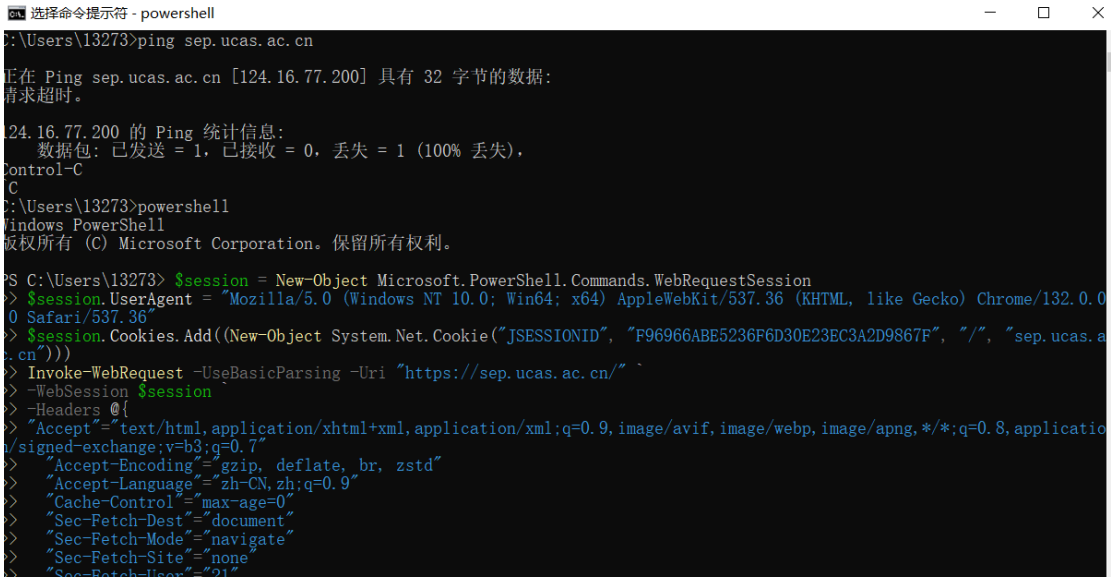
192.168.134.125	119.3.32.96	TLSv1.2	571	1 Client Hello (SNI=api.vc.bilibili.com)
119.3.32.96	192.168.134.125	TLSv1.2	1514	2 Server Hello
119.3.32.96	192.168.134.125	TLSv1.2	1510	Certificate, Server Key Exchange, Server Hello Done
192.168.134.125	119.3.32.96	TLSv1.2	180	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
192.168.134.125	119.3.32.96	TLSv1.2	159	Application Data
192.168.134.125	119.3.32.96	TLSv1.2	1318	Application Data
119.3.32.96	192.168.134.125	TLSv1.2	312	New Session Ticket, Change Cipher Spec, Encrypted Handshake Message
119.3.32.96	192.168.134.125	TLSv1.2	1082	9 Application Data, Application Data, Application Data, Application Data
192.168.134.125	119.3.32.96	TLSv1.2	92	Application Data
192.168.134.125	119.3.32.96	TLSv1.2	170	Application Data
119.3.32.96	192.168.134.125	TLSv1.2	866	Application Data
119.3.32.96	192.168.134.125	TLSv1.2	93	Application Data

我们以国科大 https://sep.ucas.ac.cn/进行 ssl/TLS 抓包，首先 ping 一下域名获取 ip 地址方便 wireshark 过滤。

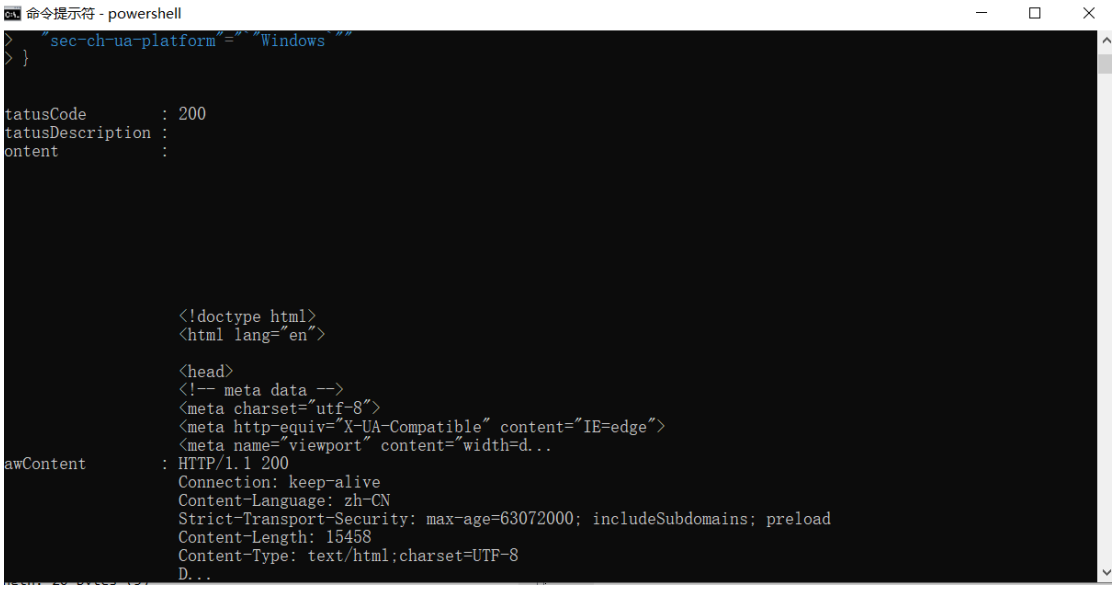
```
C:\Users\13273>ping sep.ucas.ac.cn

正在 Ping sep.ucas.ac.cn [124.16.77.200] 具有 32 字节的数据:
请求超时。
```

得到地址为 124.16.77.200，之后为了方便观察特定请求，不被太多请求干扰，构造一个 curl 请求，这能确保只有一次 SSL/TLS 握手请求。

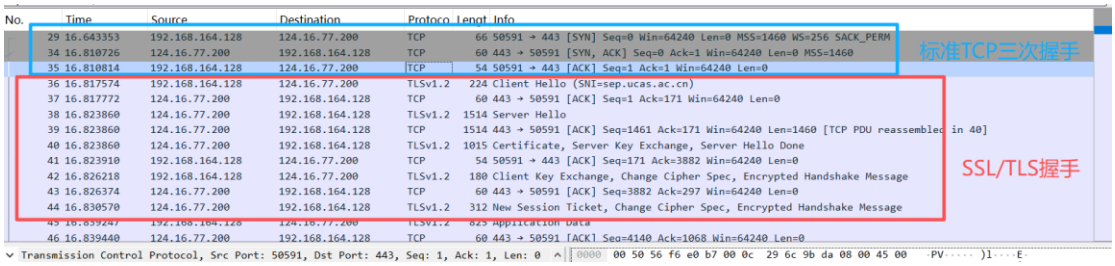
```
$session = New-Object Microsoft.PowerShell.Commands.WebRequestSession
$session.UserAgent = "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0 Safari/537.36"
$session.Cookies.Add((New-Object System.Net.Cookie("JSESSIONID", "F96966ABE5236F6D30E23EC3A2D9867F", "/", "sep.ucas.ac.cn")))
Invoke-WebRequest -UseBasicParsing -Uri "https://sep.ucas.ac.cn/" `
-WebSession $session `
-Headers @{
"Accept"="text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7"
  "Accept-Encoding"="gzip, deflate, br, zstd"
  "Accept-Language"="zh-CN,zh;q=0.9"
  "Cache-Control"="max-age=0"
  "Sec-Fetch-Dest"="document"
  "Sec-Fetch-Mode"="navigate"
  "Sec-Fetch-Site"="none"
  "Sec-Fetch-User"="?1"
  "Upgrade-Insecure-Requests"="1"
  "sec-ch-ua"="`"Not A(Brand`";v=`"8`", `"Chromium`";v=`"132`", `"Google Chrome`";v=`"132`""
  "sec-ch-ua-mobile"="?0"
  "sec-ch-ua-platform"="`"Windows`""
}
```



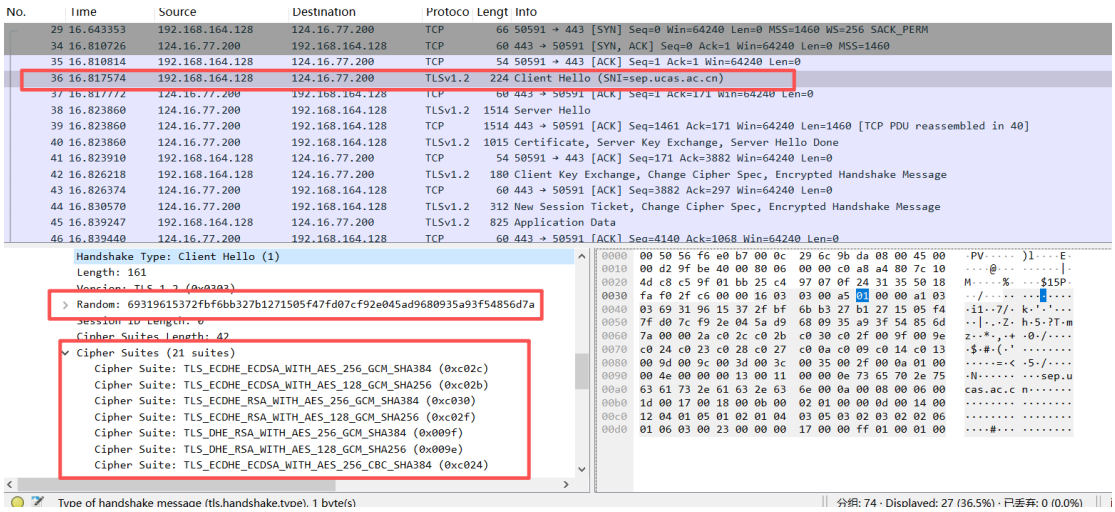
可以看到响应正确



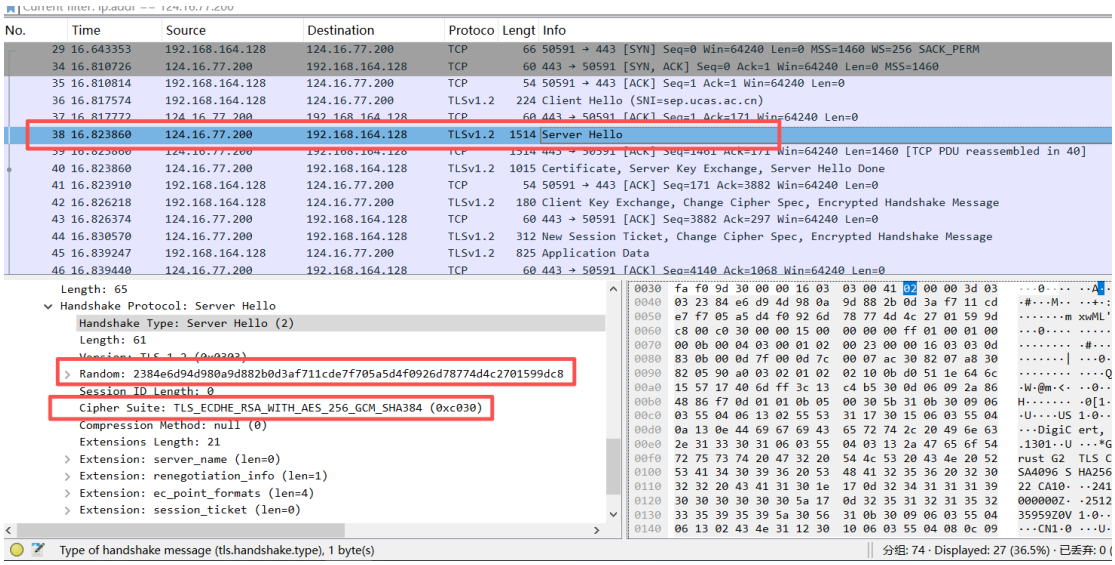
观察 wireshark，使用过滤条件为 ip.addr==124.16.77.200



之后我们来看 client hello 消息，从下图中可以看到，这是 client hello 消息，客户端生成了第一随机数并且给出了支持的加密套件。

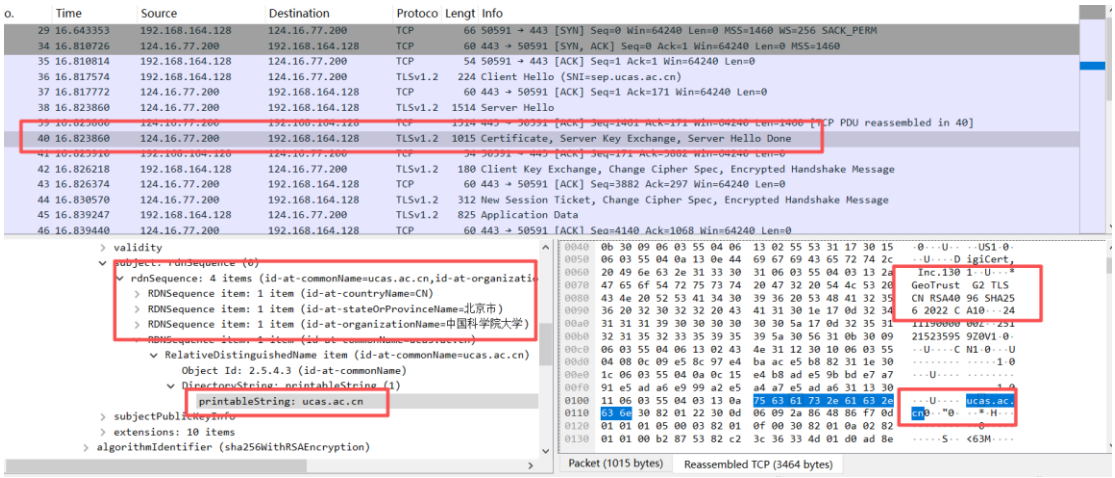


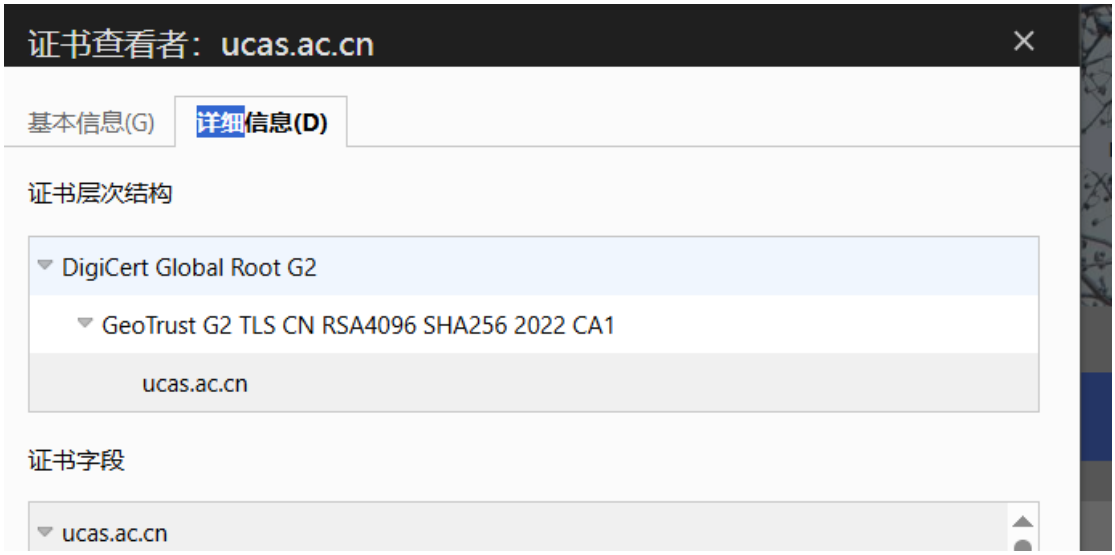
之后来看 server hello，可以看到，服务端生成了第二随机数，并且选择了客户端支持的 0xc030 作为加密套件。



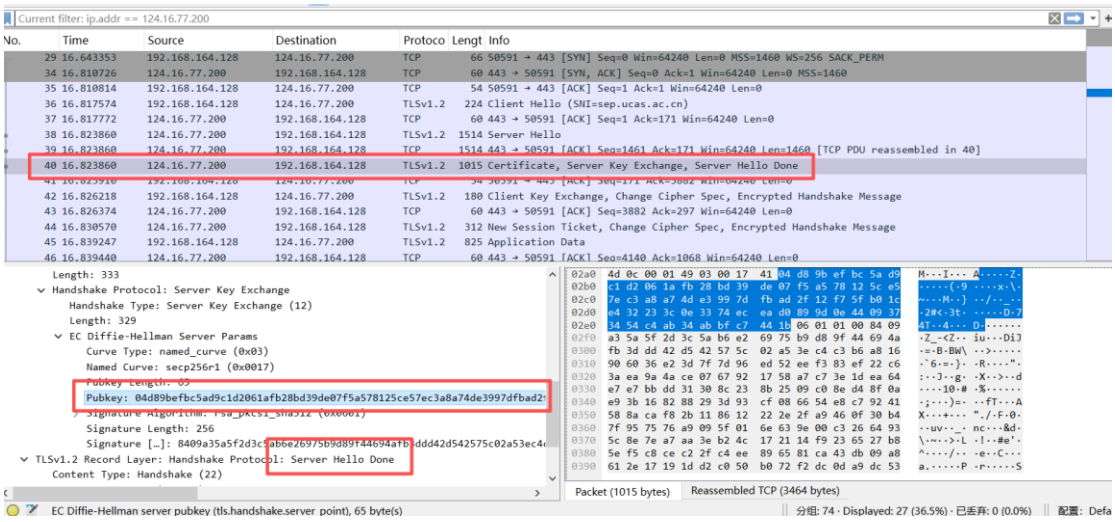
之后继续看 server certificate，server key exchange 和 server hello done 消息，这三个为一条消息。

首先我们来看一下服务器的证书信息，从下图中可以看出，这个证书是由 GeoTrust 颁发给 ucas.ac.cn 这个域名的。和我们从网页中查看到的一样。

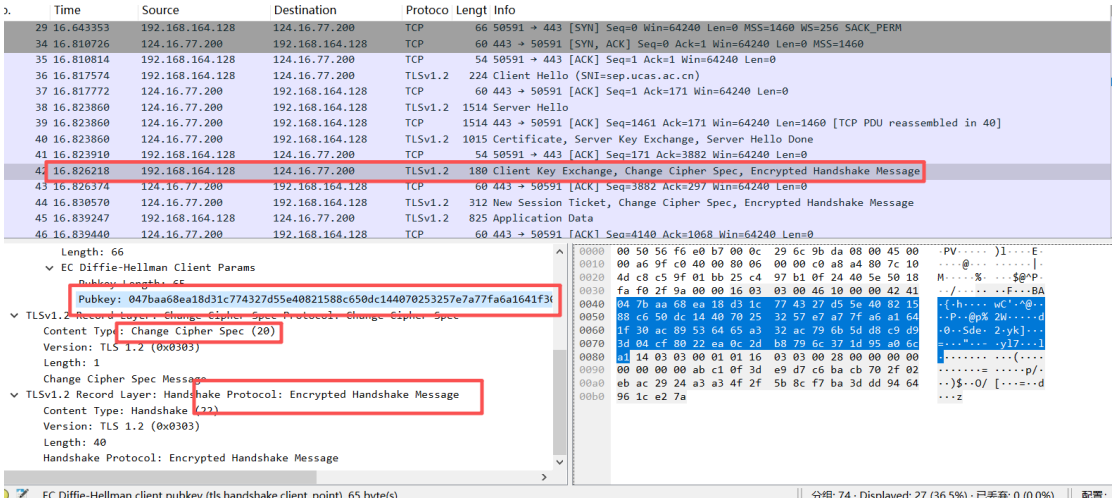




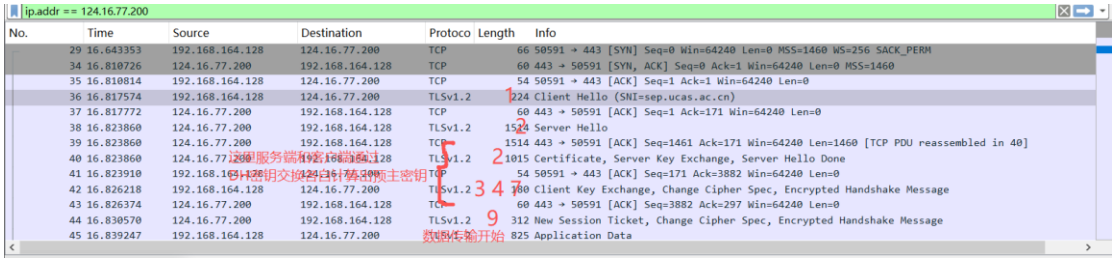
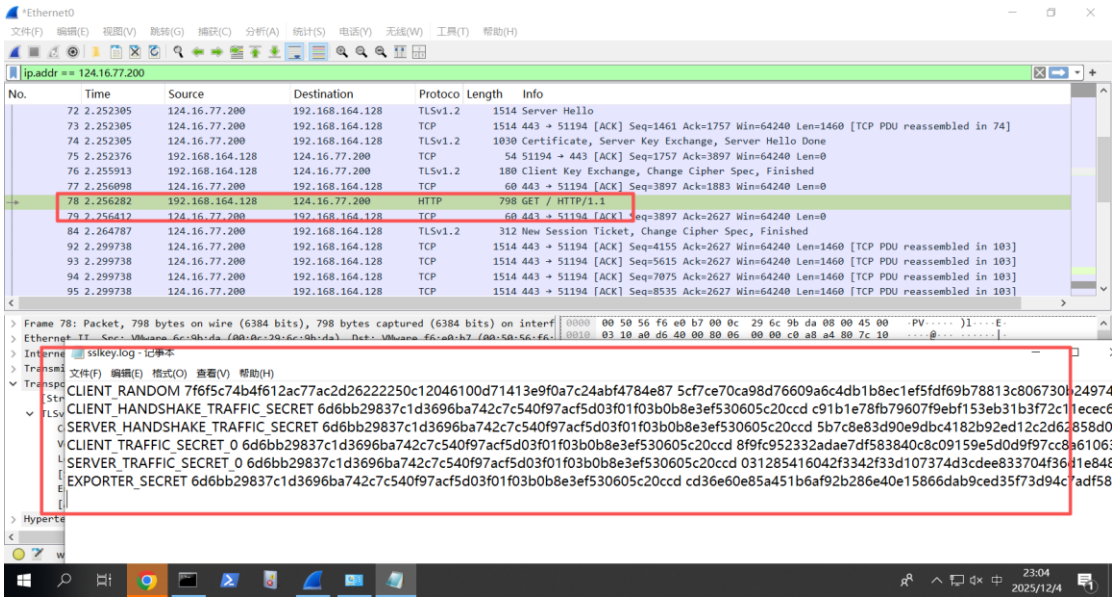
之后再来看一下公钥信息，此时是采用了 DH 密钥交换算法，从图中可以看出，服务器发送给了客户端一个 pubkey，作为 dh 参数，之后发送 server hello done 代表消息结束。



之后再来看一下客户端的，此时，客户端也生成了用于 dh 密钥交换的第二个参数，将此参数发送给服务器，此时服务器和客户端就可以独立计算出预主密钥了，之后客户端发送 change cipher spec 和 encrypted handshake message 代表可以进行加密传输了。



至此，整个 ssl/TLS 握手抓包完毕，此次并不是服务端直接出示公钥，客户端使用公钥加密预主密钥发送，而是使用 DH 密钥交换，双方交换公钥信息，独立计算预主密钥。Ssl/TLS 握手整个流程如下。



在 wireshark 可以解密 https 流量，只需要让 wireshark 能够计算出预主密钥即可，配置用户环境变量 SSLKEYLOGFILE 为 C:\users\13273\Desktop\sslkey.log，在 wireshark 中编辑->首选项->protocol->TLS 选择文件路径，即可解密 https 流量，效果如下，可见 https 流量已经被标记为 http 流量。